# Workshop 2026 — Groupe 6

*PROJECT RESILIENCE-ALPHA · Dossier de gouvernance — état au 20/10/2026*

## Organisation de l'équipe

### Répartition des domaines (WOR-18)

Chaque pilier a un responsable. Les décisions d'architecture restent prises ensemble.

| Domaine | Responsable | Projet Linear | Tickets assignés |
|---|---|---|---|
| Développement | Michael | Développement — SI de paiement & remédiation | WOR-33 à WOR-42 (10) |
| Infrastructure | Reza | Infrastructure & Observabilité | WOR-43 à WOR-49 (7) |
| IA / Data | Léa | IA / Data — Détection ML & Assistant RAG | WOR-50 à WOR-57 (8) |
| Cybersécurité | Axel | Cybersécurité — Red Team & Défense | WOR-58 à WOR-66 (9) |
| Gouvernance / Transformation | Cédric | Gouvernance & Transformation | WOR-67 à WOR-73 (7) |

Les 35 tickets communs (Pilotage, Cadrage, Intégration, Livrables) n'ont pas encore de responsable.

### Avancement du pilier Gouvernance au 20/10/2026

| Ticket | Sujet | Statut | Livrable |
|---|---|---|---|
| WOR-31 | Matrice de risques EBIOS RM, version initiale | Terminé, validé par les coachs | Partie « EBIOS RM » |
| WOR-68 | Services critiques et coût d'un arrêt de paiement | Terminé | Partie « Services critiques » |
| WOR-69 | Analyse NIS2 / DORA | En cours, version 0.1 | Partie « Analyse NIS2 / DORA » |
| WOR-70 | Objectifs RTO / RPO | En cours, version 0.1 | Partie « Objectifs RTO / RPO » ; temps mesurés attendus des essais (WOR-79) |
| WOR-71 | PCA / PRA | En cours, version 0.1 | Partie « PCA / PRA » ; à confirmer par les essais (WOR-75, WOR-76, WOR-78) |
| WOR-72 | Recommandations et arbitrages pour une direction | En cours, version 0.1 | Partie « Recommandations à la direction » |
| WOR-67 | EBIOS RM complet (ateliers 3 à 5) | À faire | Débloqué par le code de la plateforme ; vulnérabilités relevées dans la partie « État d'implémentation » |
| WOR-73 | Relier EBIOS et PCA/PRA à l'architecture et aux essais | Commencé | Partie « État d'implémentation » ; résultats des essais de mercredi et jeudi à ajouter |

## Décisions en attente avec les autres piliers

- **Avant les essais** : moteur de remédiation, modèle de détection et sauvegarde de la base ne sont pas encore codés ; le WAF est en place mais l'API n'est pas encore derrière lui (partie « État d'implémentation »).
- **Restauration de la base après une injection** : un snapshot seul fait perdre des transactions confirmées, alors que l'objectif est zéro. Proposition : snapshot puis rejeu des transactions légitimes (Michael, Reza).
- **Délai de détection compatible avec le Clip Chrono de 60 s** : la collecte passe déjà toutes les 5 s ; reste la détection, entre 20 et 70 s selon le remplissage de la fenêtre de 60 s, à mesurer (Léa).
- **Règles de l'automate** : deux signaux concordants avant une action destructrice, au plus 3 remédiations en 10 minutes (Michael).

# EBIOS RM — Matrice de risques (version initiale)

> ***Statut : cible.*** *Ce document décrit ce que l'équipe vise et a décidé, pas ce qui est déjà codé. L'état réel du code est suivi dans* `constat/etat-implementation.md`*.*

> *Ticket : WOR-31 · Responsable : Cédric · Version 0.1 du 19/10/2026,* ***validée par les coachs*** *(WOR-32)*
>
> *Cette version couvre les* ***ateliers 1 et 2****. Les ateliers 3 à 5 (scénarios stratégiques et opérationnels, traitement du risque) seront faits dans WOR-67, une fois l'architecture (WOR-27) et le scénario d'attaque (WOR-29) arrêtés.*

## Hypothèses de travail

- L'entreprise est un **opérateur de paiement fictif**. Il traite les paiements de commerçants partenaires pour des utilisateurs finaux. Toutes les données sont fictives.
- Le démonstrateur tourne sur **un seul PC Hôte**, avec Docker Compose sur le réseau `RESILIENCE-G6`. L'attaque vient d'un PC Attaquant distinct.
- Le coût d'un arrêt est chiffré dans `services-critiques.md` (WOR-68). Les objectifs RTO/RPO seront arrêtés dans WOR-70.

---

## Atelier 1 — Cadrage et socle de sécurité

### 1.1 Valeurs métier

| ID | Valeur métier | Nature | Responsable métier (fictif) |
|---|---|---|---|
| VM1 | Traitement des paiements : initier, autoriser, enregistrer une transaction | Processus | Direction des opérations |
| VM2 | Consultation des transactions par les partenaires et les utilisateurs | Processus | Direction des opérations |
| VM3 | Authentification et gestion des accès | Processus | RSSI |
| VM4 | Données de comptes et de transactions | Information | DPO / Direction financière |
| VM5 | Traçabilité : journaux et preuves d'audit | Information | RSSI / Conformité |
| VM6 | Capacité de détection et de reprise automatique | Processus | Direction de la production |

### 1.2 Biens supports

| ID | Bien support | Valeurs métier portées |
|---|---|---|
| BS1 | Front web de paiement | VM1, VM2 |
| BS2 | API métier de paiement (Node.js, `app/backend/`) | VM1, VM2, VM4 |
| BS3 | Authentification : sessions stockées en base, intégrée à l'API (pas de service séparé au 20/10) | VM3 |
| BS4 | Base PostgreSQL (utilisateurs, sessions, intentions de paiement) | VM1, VM4 |
| BS5 | WAF / reverse proxy | VM1, VM2, VM3 |
| BS6 | Stack d'observabilité (Prometheus, Loki, Grafana) et SIEM | VM5, VM6 |
| BS7 | Service d'inférence ML (détection d'anomalies) | VM6 |

| ID | Bien support | Valeurs métier portées |
|---|---|---|
| BS8 | Moteur de remédiation, playbooks Ansible, accès au moteur Docker | VM6, puis indirectement toutes |
| BS9 | Gestion des secrets (HashiCorp Vault) | VM3, VM4 |
| BS10 | Assistant RAG (Ollama, LangChain) | VM6 (aide aux opérateurs) |
| BS11 | PC Hôte et réseau `RESILIENCE-G6` | Toutes |
| BS12 | Dépôt Git et procédure de déploiement | VM6 |

> ***Point d'attention :*** *BS8 (le moteur de remédiation) a des droits élevés sur tous les conteneurs. C'est le bien support le plus sensible du dispositif (voir ER6).*
>
> ***Alignement sur le code (20/10) :*** *BS7 (inférence ML) et BS8 (remédiation) ne sont pas encore codés. BS5 (WAF) est déployé dans le socle, mais l'API n'est pas encore derrière lui. Les vulnérabilités relevées dans le code (port de la base publié, secrets en clair, code de vérification renvoyé par l'API, appel à OpenAI) sont listées dans `constat/etat-implementation.md` §3 et seront traitées dans les ateliers 3 à 5 (WOR-67).*

### 1.3 Événements redoutés

Échelle de gravité : **G1** mineure · **G2** significative · **G3** grave · **G4** critique.

Pour une indisponibilité, l'échelle est chiffrée dans `services-critiques.md` (WOR-68) : G1 ≤ 5 min (~1,5 k€), G2 ≤ 30 min (~10 k€), G3 ≤ 2 h (~700 k€, SLA dépassé), G4 > 2 h (> 1,5 M€, incident majeur DORA).

| ID | Événement redouté | VM | Impacts | Gravité |
|---|---|---|---|---|
| ER1 | Paiements indisponibles au-delà du RTO | VM1 | Transactions des partenaires bloquées, perte de chiffre d'affaires, perte de confiance, incident majeur à déclarer (DORA) | **G4** |
| ER2 | Transactions altérées ou incohérentes (montant modifié, double débit, transaction fantôme) | VM1, VM4 | Préjudice financier direct, litiges, données comptables fausses | **G4** |
| ER3 | Fuite des données de comptes ou de transactions | VM4 | Atteinte à la vie privée (RGPD), sanctions, atteinte à l'image | **G3** |
| ER4 | Accès non autorisé à un compte (usurpation d'identité) | VM3 | Fraude, opérations frauduleuses initiées | **G3** |
| ER5 | Journaux perdus ou altérés | VM5 | Investigation impossible, preuves perdues, non-conformité | **G3** |
| ER6 | Moteur de remédiation détourné ou en erreur (arrêt de services, restauration de mauvaises données) | VM6 → VM1 | Interruption provoquée par le dispositif de défense lui-même, possibilité de rebond sur tout le SI | **G4** |
| ER7 | Consultation des transactions indisponible | VM2 | Gêne pour les partenaires, appels au support | **G2** |

### 1.4 Socle de sécurité

| Référentiel | Applicabilité | Écarts connus à ce stade |
|---|---|---|
| DORA (règlement UE 2022/2554) | Applicable : entité financière | Pas de tests de résilience menés par un tiers, pas de gestion des prestataires TIC (voir WOR-69) |

| Référentiel | Applicabilité | Écarts connus à ce stade |
|---|---|---|
| NIS2 (directive UE 2022/2555) | Le secteur bancaire et les infrastructures des marchés financiers sont couverts, mais DORA s'applique en priorité | Analyse à faire dans WOR-69 |
| RGPD | Applicable par principe (données personnelles fictives) | Aucune donnée réelle, donc écart sans conséquence pour le prototype |
| Guide d'hygiène informatique de l'ANSSI | Bonnes pratiques de référence | Hôte unique (point de défaillance unique), pas de sauvegarde hors site |
| PCI DSS | Référence du secteur pour les données de carte | **Hors périmètre** : aucune donnée de carte manipulée |

---

## Atelier 2 — Sources de risque et objectifs visés

Cotation de la pertinence : **1** faible · **2** moyenne · **3** forte. Elle combine la motivation, les ressources et l'activité constatée de la source.

| ID | Source de risque (SR) | Objectif visé (OV) | Motivation | Ressources | Pertinence | Retenu ? |
|---|---|---|---|---|---|---|
| SR1 | Cybercriminel organisé | Gain financier : fraude aux paiements, rançongiciel | Forte | Importantes | **3** | ✅ |
| SR2 | Hacktiviste | Visibilité, nuire à l'image : déni de service | Moyenne | Moyennes (botnets loués) | **3** | ✅ |
| SR3 | Initié malveillant (employé, prestataire) | Vengeance ou gain : sabotage, fraude interne | Moyenne | Accès légitimes | **2** | ✅ |
| SR4 | Attaquant opportuniste | Défi, revente d'accès : exploitation d'une vulnérabilité web, bourrage d'identifiants | Faible | Outils publics | **2** | ✅ |
| SR5 | Concurrent ou officine d'espionnage | Vol de données commerciales | Faible | Moyennes | 1 | ❌ données fictives, sans valeur concurrentielle |
| SR6 | Acteur étatique (APT) | Déstabiliser le secteur financier | Faible pour une petite entité | Très importantes | 1 | ❌ hors de portée d'un prototype de 4 jours, cité comme risque résiduel |

> *Les événements non intentionnels (erreur d'exploitation, panne, faux positif du modèle ML) ne sont pas des sources de risque au sens d'EBIOS. Ils seront traités dans le PCA/PRA (WOR-71).*

---

## Matrice de risques initiale

Vraisemblance provisoire : **V1** peu vraisemblable · **V2** vraisemblable · **V3** très vraisemblable · **V4** quasi certain. Elle sera affinée dans les ateliers 3 et 4.

| ID | Risque (SR → mode d'action → ER) | Gravité | Vraisemblance | Niveau |
|---|---|---|---|---|
| R1 | SR2 → déni de service applicatif sur l'API ou le front → ER1 | G4 | V3 | 🔴 Élevé |
| R2 | SR1 → injection applicative sur l'API → ER2 | G4 | V2 | 🔴 Élevé |
| R3 | SR3 → détournement des droits du moteur de remédiation → ER6 | G4 | V2 | 🔴 Élevé |
| R4 | SR4 → bourrage d'identifiants ou force brute sur l'authentification → ER4 | G3 | V3 | 🟠 Significatif |
| R5 | SR1 → compromission puis exfiltration de la base → ER3 | G3 | V2 | 🟠 Significatif |
| R6 | SR3 → effacement ou altération des journaux → ER5 | G3 | V2 | 🟠 Significatif |
| R7 | SR1 → rançongiciel sur le PC Hôte → ER1, ER3 | G4 | V1 | 🟠 Significatif |
| R8 | SR2 → saturation de la consultation → ER7 | G2 | V3 | 🟡 Modéré |

### Cartographie

| Gravité \ Vraisemblance | V1 | V2 | V3 | V4 |
|---|---|---|---|---|
| **G4** | R7 | R2, R3 | **R1** | |
| **G3** | | R5, R6 | R4 | |
| **G2** | | | R8 | |
| **G1** | | | | |

### Lecture

- **R1 (déni de service)** est le risque le plus élevé. C'est aussi le meilleur candidat pour le scénario d'attaque de la démo (WOR-29) : effet observable, détectable par le ML et réparable automatiquement.
- **R2 et R5** (injection, exfiltration) appellent une réponse différente d'une simple restauration de la disponibilité. Le sujet demande explicitement de ne pas confondre les deux (voir WOR-39).
- **R3** porte sur notre propre dispositif de défense. Il justifie WOR-64 (sécuriser le moteur de remédiation), que le jury évalue sur l'Axe 2.

---

## Validation par les coachs (WOR-32)

La version initiale (ateliers 1 et 2) a été validée par les coachs. Remarques éventuelles des coachs : à reporter ici.

Points qui leur ont été soumis :

1. Le périmètre des valeurs métier : faut-il garder VM6 (la capacité de reprise) comme valeur métier, ou seulement comme bien support ?
2. Les sources de risque écartées (SR5 et SR6) et leur justification.
3. Le choix de R1 comme scénario principal de la démo.
4. L'échelle de gravité chiffrée (durée d'arrêt et coût, voir `services-critiques.md`) : les hypothèses sur l'entreprise fictive sont-elles crédibles ?

## Suites

- **WOR-67** : ateliers 3 à 5, avec les chemins d'attaque sur les biens supports réels et les mesures de traitement.
- **WOR-73** : relier chaque risque aux composants et aux résultats des tests.

# Services critiques et coût d'un arrêt de paiement

> ***Statut : cible.*** *Ce document décrit ce que l'équipe vise et a décidé, pas ce qui est déjà codé. L'état réel du code est suivi dans `constat/etat-implementation.md`.*

> *Ticket : WOR-68 · Responsable : Cédric · Version 0.1 du 19/10/2026*
>
> *Ce document sert d'entrée à l'EBIOS RM (échelle de gravité, voir `ebios-rm.md`), aux objectifs RTO/RPO (WOR-70) et au PCA/PRA (WOR-71).*

## Hypothèses sur l'entreprise fictive

Tous les chiffres sont **fictifs**. Ils sont choisis pour donner des ordres de grandeur réalistes à un opérateur de paiement de taille moyenne.

| Paramètre | Valeur retenue | Commentaire |
|---|---|---|
| Transactions par jour | 1 200 000 | Soit environ 830 par minute en moyenne |
| Montant moyen d'une transaction | 45 € | Paiement de détail |
| Flux traité par jour | 54 M€ | 1 200 000 × 45 € |
| Commission moyenne | 0,8 % | Revenu de l'opérateur sur chaque transaction |
| Revenu par jour | 432 k€ | Soit environ 158 M€ par an |
| Facteur des heures de pointe | × 2,5 | 12 h–14 h et 18 h–20 h |
| Taux d'abandon définitif pendant un arrêt | 40 % | Les autres transactions sont rejouées après la reprise |
| Commerçants partenaires | 200 | Liés par un contrat de niveau de service |
| Engagement de disponibilité (SLA) | 99,9 % par mois | Soit 43 minutes d'arrêt tolérées par mois |
| Pénalité en cas de dépassement du SLA | 5 % de la facture mensuelle | Environ 650 k€ si tous les partenaires sont touchés |

## Coût d'un arrêt du traitement des paiements

### Perte directe par minute

| | Moyenne | Heure de pointe |
|---|---|---|
| Transactions bloquées par minute | 830 | 2 080 |
| Flux bloqué par minute | 37 500 € | 93 750 € |
| Revenu bloqué par minute | 300 € | 750 € |
| **Revenu perdu définitivement par minute** (40 % d'abandon) | **120 €** | **300 €** |

La perte directe reste modeste. **Le vrai coût vient des effets de seuil** : la pénalité contractuelle, l'obligation réglementaire et la perte de confiance.

### Coût selon la durée (incident en heure de pointe)

| Durée de l'arrêt | Perte directe | Effets de seuil | Coût total estimé | Gravité EBIOS |
|---|---|---|---|---|
| ≤ 5 min | 1 500 € | Aucun | ~1,5 k€ | G1 mineure |

| Durée de l'arrêt | Perte directe | Effets de seuil | Coût total estimé | Gravité EBIOS |
|---|---|---|---|---|
| 5 à 30 min | jusqu'à 9 k€ | Hausse des appels au support | ~10 k€ | G2 significative |
| 30 min à 2 h | jusqu'à 36 k€ | Budget SLA mensuel de 43 min dépassé, donc pénalité d'environ 650 k€ ; incident probablement majeur au sens de DORA (critère économique) | ~700 k€ | G3 grave |
| > 2 h | 36 k€ et plus | Pénalité SLA, incident **majeur au sens de DORA** (notification à l'ACPR), départ estimé de 0,5 % des partenaires (environ 790 k€ par an) | > 1,5 M€ | G4 critique |

> *Le seuil DORA de 2 h d'interruption d'un service critique vient des critères de classification des incidents (règlement délégué (UE) 2024/1772). Ce n'est pas le seul critère : dès que la pénalité SLA est déclenchée, l'impact économique dépasse 100 k€ et, avec les partenaires touchés, l'incident devient probablement majeur* ***dès la tranche 30 min à 2 h****. Le détail est dans* `nis2-dora.md` *(WOR-69).*

**À retenir :** l'arrêt coûte peu tant qu'il dure moins de quelques minutes, puis le coût explose. C'est l'argument central en faveur de la reprise automatique : une reprise manuelle (30 min et plus, d'après le contexte du sujet) fait basculer l'incident en G3, alors qu'une reprise automatique en quelques minutes le maintient en G1.

## Services critiques par ordre de priorité

| Rang | Service | Criticité | Pourquoi | Dégradation acceptable |
|---|---|---|---|---|
| 1 | Traitement des transactions (API de paiement et base de données) | **Vitale** | Porte directement le revenu et l'engagement envers les partenaires | Aucune |
| 2 | Authentification | **Vitale** | Sans elle, aucune transaction ne peut être initiée. Intégrée à l'API, avec des sessions stockées en base : elle tombe avec la base | Aucune |
| 3 | WAF / point d'entrée | **Vitale** | Point de passage unique de tout le trafic | Un contournement temporaire n'est **pas** acceptable (exposition directe) |
| 4 | Journalisation et SIEM | Importante | Aucun revenu en jeu, mais elle est indispensable à l'investigation et à la conformité | Arrêt de quelques heures, **sans perte** de journaux |
| 5 | Consultation de l'historique | Importante | Gêne pour les partenaires, sans perte de revenu | Mode dégradé possible (lecture différée) |
| 6 | Supervision, détection ML, moteur de remédiation | Support critique | N'est pas un service métier, mais conditionne la reprise de tous les autres | Arrêt de courte durée, avec retour à une surveillance manuelle |
| 7 | Assistant RAG | Non critique | Aide les opérateurs ; le service rendu aux clients n'en dépend pas | Indisponibilité acceptable |

## Ce qu'on protège en priorité

1. **La continuité du traitement des paiements** (rangs 1 à 3) : la reprise automatique doit viser un retour en service en moins de 5 minutes.
2. **L'intégrité des transactions déjà validées** : une transaction confirmée ne doit jamais être perdue ni dupliquée. Une transaction perdue coûte bien plus cher qu'une minute d'arrêt (litiges, écritures comptables fausses).
3. **La conservation des journaux** : sans eux, impossible d'expliquer l'incident au régulateur ni d'améliorer la détection.

## Pistes pour les RTO / RPO

> *Objectifs arrêtés, répartition du RTO sur la chaîne de reprise et protocole de mesure : voir `rto-rpo.md` (WOR-70).*

| Service | RTO proposé | RPO proposé |
|---|---|---|
| Traitement des transactions | ≤ 5 min | 0 (aucune transaction validée perdue) |
| Authentification | ≤ 5 min | Sans objet (service sans état) |
| Journalisation | ≤ 1 h | 0 |
| Consultation | ≤ 30 min | 0 |
| Assistant RAG | Meilleur effort | Sans objet |

# Analyse NIS2 / DORA

> ***Statut : cible.*** *Ce document décrit ce que l'équipe vise et a décidé, pas ce qui est déjà codé. L'état réel du code est suivi dans* `constat/etat-implementation.md`*.*

> *Ticket : WOR-69 · Responsable : Cédric · Version 0.1 du 19/10/2026*
>
> *Ce document s'appuie sur la matrice de risques (*`ebios-rm.md`*) et sur le coût d'un arrêt (*`services-critiques.md`*). Il alimente le PCA/PRA (WOR-71) et les recommandations à la direction (WOR-72).*
>
> *Le sujet demande de* ***distinguer les exigences pertinentes des obligations qui ne peuvent pas être démontrées par un prototype de quatre jours****. C'est la structure de ce document : pour chaque exigence, ce que le démonstrateur prouve, et ce qu'il ne prouve pas.*

## 1. Quel texte s'applique ?

| Question | Réponse | Fondement |
|---|---|---|
| Notre entreprise fictive est-elle dans le champ de DORA ? | **Oui.** Un opérateur de paiement est un établissement de paiement, explicitement visé. | DORA (règlement UE 2022/2554), art. 2.1 b. Applicable depuis le 17/01/2025. |
| Est-elle dans le champ de NIS2 ? | **Indirectement.** Le secteur bancaire de l'annexe I de NIS2 vise les établissements de crédit, pas les établissements de paiement en tant que tels. | NIS2 (directive UE 2022/2555), annexe I. |
| Si les deux s'appliquaient, lequel prime ? | **DORA.** C'est un acte sectoriel qui prévoit des mesures au moins équivalentes ; il remplace NIS2 pour la gestion du risque et la notification des incidents. | NIS2, art. 4 et considérant 28. |
| Qui est l'autorité compétente ? | L'**ACPR** pour un établissement de paiement en France. | Désignation nationale au titre de DORA. |
| Le cadre simplifié (art. 16) s'applique-t-il ? | **Non.** Avec 158 M€ de revenu annuel et 200 partenaires, l'entreprise n'est pas une petite structure exemptée. | DORA, art. 16. |

**Conclusion :** on raisonne en DORA. NIS2 reste utile comme grille de lecture (mesures de l'art. 21, chaîne d'approvisionnement), mais ce n'est pas le texte qui nous oblige.

## 2. Ce que DORA exige, et ce que le démonstrateur prouve

Légende : ✅ démontré par le prototype · 🟡 démontré en partie · ❌ non démontrable en 4 jours (à traiter dans un contexte industriel).

Les biens supports (BS) sont ceux de `ebios-rm.md`. Les preuves sont **prévues** : elles seront confirmées par les résultats d'essais du mercredi et du jeudi (WOR-73). L'état réel du code au 20/10 est suivi dans `constat/etat-implementation.md`.

## 2.1 Gestion du risque TIC (art. 5 à 16)

| Exigence | Article | Ce que le prototype montre | Composants | Preuve attendue | Statut |
|---|---|---|---|---|---|
| Cadre de gestion du risque TIC documenté | 6 | Analyse EBIOS RM, services critiques chiffrés | — | `ebios-rm.md`, `services-critiques.md` | ✅ |
| Identifier les fonctions critiques et leurs dépendances | 8 | Services classés par priorité, biens supports reliés aux valeurs métier | Tous | Tableaux VM ↔ BS | ✅ |
| Protection et prévention : moindre privilège, chiffrement, gestion des secrets | 9 | Filtrage WAF, secrets hors du code, privilèges limités des conteneurs | BS5, BS9, BS8 | Configuration WAF, HashiCorp Vault, revue des droits du moteur de remédiation (WOR-64) | 🟡 un seul hôte ; au 20/10, WAF en place mais l'API pas encore derrière lui, secrets de l'application hors de Vault, port de la base publié |
| Détection rapide des activités anormales | 10 | Détection ML sur les métriques et journaux, alertes SIEM | BS6, BS7 | Horodatage attaque → alerte, mesuré pendant l'essai | 🟡 prévu : au 20/10, features extraites mais pas encore de modèle ni d'alerte |
| Réponse et rétablissement : politique de continuité, reprise des fonctions critiques | 11 | **Cœur de la démo** : remédiation automatique, puis transaction fictive réussie | BS8, BS2, BS4 | Durée attaque → transaction réussie, comparée au RTO (WOR-70) | 🟡 prévu : au 20/10, moteur de remédiation pas encore codé |
| Tests du plan de continuité | 11.6 | Scénario d'attaque rejoué et chronométré | Tous | Résultats d'essais | 🟡 un seul scénario, pas de programme annuel |
| Sauvegarde et restauration, sans perte de données validées | 12 | Restauration de la base, contrôle de cohérence après reprise | BS4 | Comptage des transactions avant / après | ❌ au 20/10, aucune sauvegarde de la base |
| Capacités redondantes | 12.4 | — | BS11 | — | ❌ hôte unique, point de défaillance unique assumé |
| Retour d'expérience après incident | 13 | Analyse post-incident à partir des journaux, aidée par l'assistant RAG | BS6, BS10 | Rapport d'incident généré après l'essai | 🟡 |
| Communication de crise | 14 | — | — | Plan de communication dans le PCA (WOR-71) | 🟡 sur papier |
| Responsabilité de l'organe de direction, formation | 5 | — | — | — | ❌ pas d'organe de direction réel |

### 2.2 Gestion et notification des incidents (art. 17 à 23)

| Exigence | Article | Ce que le prototype montre | Statut |
|---|---|---|---|
| Processus de détection, journalisation et suivi des incidents | 17 | Chaque incident détecté est horodaté et conservé dans le SIEM | 🟡 au 20/10, blocages du WAF et accès à Vault journalisés et visibles dans le tableau SOC/SIEM ; pas encore de règle d'alerte ni de suivi d'incident |
| Classification selon les critères réglementaires | 18 | Grille appliquée au scénario de la démo (voir section 3) | ✅ sur papier, à partir des mesures réelles |
| Notification des incidents majeurs à l'ACPR : initiale, intermédiaire, finale | 19 | Les journaux du SIEM contiennent les informations nécessaires. Aucune notification réelle n'est envoyée. | 🟡 |
| Information des clients touchés | 19.3 | — | ❌ |

### 2.3 Tests de résilience (art. 24 à 27)

| Exigence | Article | Ce que le prototype montre | Statut |
|---|---|---|---|
| Programme de tests : analyses de vulnérabilités, tests de scénarios, tests de performance | 24, 25 | Scénario Red Team depuis le PC Attaquant, scans de vulnérabilités | 🟡 un essai ponctuel, pas un programme |
| Tests de pénétration fondés sur la menace (TLPT), tous les 3 ans, par des testeurs indépendants | 26, 27 | — | ❌ réservé aux entités désignées, exige des testeurs externes |

### 2.4 Risque lié aux prestataires TIC (art. 28 à 44)

| Exigence | Article | Ce que le prototype montre | Statut |
|---|---|---|---|
| Registre des accords avec les prestataires TIC | 28.3 | Inventaire des briques utilisées (images Docker, Ollama, modèles) | 🟡 inventaire technique, pas contractuel |
| Clauses contractuelles obligatoires, stratégies de sortie | 28.8, 30 | — | ❌ aucun contrat |
| Concentration du risque sur un prestataire | 29 | Tout est auto-hébergé, sauf l'assistant de discussion de l'application, qui appelle OpenAI | 🟡 un prestataire externe à inscrire au registre, ou à remplacer par le modèle local (Ollama) |

### 2.5 Partage d'informations (art. 45)

Facultatif. Non traité.

## 3. Le scénario de la démo est-il un incident majeur ?

DORA classe un incident comme **majeur** s'il touche un service critique et, en plus, soit entraîne une perte de données après un accès malveillant, soit dépasse les seuils d'au moins deux autres critères (règlement délégué (UE) 2024/1772). Les critères utiles ici :

- **Durée** : interruption d'un service critique de plus de 2 h (ou incident de plus de 24 h) ;
- **Clients touchés** : plus de 10 % des clients ou des contreparties financières ;
- **Impact économique** : plus de 100 k€ de coûts et pertes ;
- **Perte de données** : atteinte à la disponibilité, l'intégrité ou la confidentialité des données.

Appliqué au risque R1 (déni de service sur l'API, scénario principal pressenti), en heure de pointe et avec les 200 partenaires touchés :

| Mode de reprise | Durée | Critères dépassés | Majeur ? | Conséquence |
|---|---|---|---|---|
| **Automatique (cible de la démo)** | ≤ 5 min | Clients touchés | **Non** | Incident enregistré et classé, pas de notification |
| Manuelle | 30 min à 2 h | Clients touchés, impact économique (pénalité SLA ~650 k€) | **Oui, probablement** | Notification initiale à l'ACPR, puis rapports intermédiaire et final |
| Manuelle, longue | > 2 h | Clients, durée, impact économique | **Oui** | Idem, et incident G4 dans EBIOS |

> ***Attention :*** *le critère économique peut faire basculer l'incident en majeur* ***avant*** *le seuil de 2 h, dès que la pénalité SLA est déclenchée (43 min d'arrêt cumulé dans le mois). Il faut donc corriger la note de* `services-critiques.md`*, qui ne cite que le seuil de durée.*

Pour R2 et R5 (injection, exfiltration), le critère « perte de données après accès malveillant » suffit, avec la criticité du service, à rendre l'incident majeur, **quelle que soit la vitesse de reprise**. Restaurer la disponibilité ne dispense pas de notifier. C'est la distinction que le sujet demande de ne pas manquer (voir WOR-39).

**Argument pour la direction :** la reprise automatique en moins de 5 minutes n'est pas seulement un gain technique. Elle maintient un déni de service sous les seuils de DORA, ce qui évite la notification réglementaire et la pénalité contractuelle.

## 4. Ce que nous ne pouvons pas démontrer, et ce qu'il faudrait en contexte industriel

| Limite du prototype | Exigence concernée | Ce qu'il faudrait faire |
|---|---|---|
| Un seul PC Hôte | Redondance (art. 12) | Deuxième site ou deuxième zone de disponibilité, bascule testée |
| Sauvegardes sur le même hôte | Sauvegarde isolée (art. 12) | Copie hors site, immuable, restauration testée chaque trimestre |
| Un seul scénario d'attaque | Programme de tests (art. 24) | Programme annuel couvrant tous les risques retenus dans EBIOS |
| Pas de testeurs indépendants | TLPT (art. 26) | Campagne TLPT (cadre TIBER-EU) si l'entité est désignée |
| Pas de contrats | Prestataires TIC (art. 28 à 30) | Registre d'information, clauses DORA, plans de sortie |
| Pas d'organe de direction | Gouvernance (art. 5) | Validation du cadre de risque par la direction, formation annuelle |
| Pas de notification réelle | Notification (art. 19) | Procédure de notification à l'ACPR, astreinte, modèles de rapports |
| Données fictives | RGPD | Analyse d'impact (AIPD) sur les données réelles |

## 5. Pistes pour les recommandations (WOR-72)

1. **Garder la reprise automatique comme priorité** : c'est elle qui maintient les incidents de disponibilité sous les seuils de DORA (section 3).

2. **Traiter à part les incidents d'intégrité et de confidentialité** : la remédiation automatique ne doit pas effacer les traces. Les journaux doivent être conservés avant toute restauration, car ils serviront à la notification.
3. **Préparer automatiquement le brouillon de notification** : le SIEM et l'assistant RAG disposent déjà des horodatages et des impacts. Un humain valide et envoie.
4. **Budgéter en priorité la redondance et les sauvegardes hors site** : ce sont les deux écarts les plus lourds face à l'art. 12.
5. **Encadrer le moteur de remédiation** (R3, WOR-64) : un dispositif de défense aux droits élevés est lui-même un bien critique au sens de l'art. 9.

## À valider avec les coachs

1. La qualification « établissement de paiement, donc DORA, NIS2 en second plan » est-elle la lecture attendue ?
2. Le niveau de détail : faut-il citer les articles, ou rester au niveau des cinq piliers de DORA pour le dossier final ?

# Objectifs RTO / RPO

> ***Statut : cible.*** *Ce document décrit ce que l'équipe vise et a décidé, pas ce qui est déjà codé. L'état réel du code est suivi dans* `constat/etat-implementation.md`*.*

> *Ticket : WOR-70 · Responsable : Cédric · Version 0.1 du 19/10/2026*
>
> *Ce document fixe les objectifs à partir du coût d'un arrêt (`services-critiques.md`) et des seuils de DORA (`nis2-dora.md`). Il définit aussi* ***comment les mesurer*** *pendant les essais (WOR-79), pour que la comparaison objectif / mesuré soit vérifiable. Il alimente le PCA/PRA (WOR-71).*

## 1. Définitions retenues

- **RTO** (durée maximale d'interruption) : temps entre le **début de l'impact** (première transaction en échec) et la **première transaction réussie et vérifiée** après la reprise. On compte depuis l'impact, pas depuis la détection : c'est ce que subissent les partenaires, et c'est ce que DORA mesure (« service downtime »).
- **RPO** (perte de données maximale admissible) : quantité de **transactions confirmées au client** qui manquent ou sont dupliquées après la reprise. On l'exprime en nombre de transactions (et en durée équivalente quand une restauration est en jeu).
- **Reprise vérifiée** : API accessible, transaction test réussie, données cohérentes (WOR-77). Un conteneur redémarré ne compte pas.

## 2. Deux niveaux d'objectifs

| Niveau | À quoi il sert | D'où il vient |
|---|---|---|
| **Objectif métier** | Ce que l'entreprise fictive exige ; c'est ce qu'on présente à la direction | Coût d'un arrêt : au-delà de 5 min, l'incident sort de G1 ; au-delà de 30 min, la pénalité SLA et la notification DORA deviennent probables |
| **Cible du démonstrateur** | Ce qu'on vise et mesure sur le PC Hôte | Objectif métier, avec de la marge, et la contrainte du Clip Chrono : 60 s en continu entre l'attaque et le service rétabli (WOR-83) |

## 3. Objectifs par service

| Service | Criticité | RTO métier | RPO métier | Cible démonstrateur | Mécanisme prévu |
|---|---|---|---|---|---|
| Traitement des transactions (API + BDD) | Vitale | **≤ 5 min** | **0** transaction confirmée perdue ou dupliquée | RTO ≤ 60 s (attaque A) · ≤ 3 min (attaque B) | Remédiation automatique (WOR-38), playbooks Ansible (WOR-44) |
| Authentification | Vitale | ≤ 5 min | Sans objet (sans état) | Retour en même temps que l'API | Redémarrage ; après une rotation de secret, reconnexion des utilisateurs acceptée |
| WAF / point d'entrée | Vitale | ≤ 5 min | Sans objet ; la configuration est versionnée | Pas de coupure : la règle de limitation s'ajoute à chaud | Configuration rechargée sans arrêt |
| Journalisation et SIEM | Importante | ≤ 1 h | **0** journal perdu | Aucune perte pendant les essais | Journaux conservés **avant** toute restauration |

| Service | Criticité | RTO métier | RPO métier | Cible démonstrateur | Mécanisme prévu |
|---|---|---|---|---|---|
| Consultation de l'historique | Importante | ≤ 30 min | 0 | Retour en même temps que l'API | Même service que l'API |
| Supervision, détection ML, remédiation | Support critique | ≤ 15 min | Sans objet ; le modèle est versionné | Hors périmètre de l'attaque | Relance par Docker Compose |
| Assistant RAG | Non critique | Meilleur effort | Sans objet ; l'index peut être reconstruit | — | Réindexation |

## 4. Répartition du RTO sur la chaîne de reprise

Le RTO se décompose en étapes. Chaque pilier tient une partie du budget. Les durées sont des **hypothèses à confirmer** avec Reza (collecte), Léa (détection) et Michael (remédiation).

| Étape | Marqueur de temps | Responsable | Budget attaque A | Budget attaque B |
|---|---|---|---|---|
| Début de l'impact → anomalie visible dans les métriques | T1 → T2 | Infrastructure (collecte Prometheus toutes les 5 s) | ≤ 5 s | ≤ 5 s |
| Anomalie visible → alerte ML | T2 → T3 | IA / Data (fenêtre de 60 s évaluée toutes les 10 s, alerte après deux fenêtres anormales consécutives) | ≈ 20 s | ≈ 20 s |
| Alerte → décision de remédiation | T3 → T4 | Développement | ≤ 5 s | ≤ 5 s |
| Décision → action terminée | T4 → T5 | Infrastructure / Développement | ≤ 15 s (limitation au WAF, redémarrage) | ≤ 2 min (blocage, restauration, rotation du secret) |
| Action terminée → transaction test réussie et données vérifiées | T5 → T6 | Développement | ≤ 10 s | ≤ 20 s |
| **Total (RTO mesuré = T6 – T1)** | | | **≤ 60 s** | **≤ 3 min** |

T0 désigne le lancement de l'attaque sur le PC Attaquant. L'écart T0 → T1 dépend de l'attaque et ne compte pas dans le RTO.

> ***Point de vigilance pour le Clip Chrono :*** *60 s, c'est T0 → T6* ***et*** *l'affichage du résultat. La collecte passe déjà toutes les 5 s (`infra/prometheus/prometheus.yml`). La détection reste le poste le plus long : environ 20 s si deux évaluations consécutives suffisent, jusqu'à 70 s si la fenêtre de 60 s doit se remplir d'abord (`docs/runbooks/reprise.md`). Le budget de 60 s est donc serré :* ***à mesurer en priorité avec Léa.***

## 5. Arbitrage à trancher : la restauration après une injection (attaque B)

WOR-29 prévoit un **retour à un snapshot propre de la base**. C'est incompatible avec un RPO de 0 : toutes les transactions légitimes validées entre le snapshot et la restauration seraient perdues.

| Option | RPO obtenu | Effort | Avis |
|---|---|---|---|
| 1. Snapshot périodique seul (par exemple toutes les 5 min) | Jusqu'à 5 min de transactions perdues | Faible | Simple, mais contredit l'objectif métier et provoque un incident majeur DORA (perte de données) |
| 2. **Snapshot + rejeu des transactions légitimes** depuis un journal en ajout seul, en écartant celles qui viennent de la source bloquée | **0** si le rejeu est correct | Moyen | **Recommandé** : démontre l'objectif métier, et le tri entre légitime et malveillant est un bon argument pour le jury |
| 3. Restauration à un instant précis (PITR, par exemple l'archivage des WAL avec PostgreSQL), juste avant la première requête malveillante | Proche de 0, mais les transactions légitimes postérieures sont perdues | Moyen à élevé | Solution industrielle de référence, à citer dans les recommandations |
| 4. Correction ciblée : annuler les seules lignes altérées, sans restauration globale | 0 | Élevé et risqué | Non retenu pour un prototype de 4 jours |

**Proposition :** option 2 pour la démo, option 3 citée comme cible industrielle. Dans tous les cas, **les journaux et l'état de la base compromise sont copiés avant la restauration** : ce sont des preuves pour l'investigation et la notification.

À valider avec Michael (WOR-38, WOR-39) et Reza (WOR-44) avant de figer WOR-29.

## 6. Protocole de mesure (pour WOR-79)

### Temps

Chaque marqueur est horodaté automatiquement, sur une **même horloge** (le PC Hôte ; le PC Attaquant est synchronisé dessus ou son décalage est noté avant chaque essai).

| Marqueur | Source |
|---|---|
| T0 lancement de l'attaque | Journal du script d'attaque (WOR-58) |
| T1 première transaction en échec | Générateur de trafic normal : première réponse en erreur ou en dépassement de délai |
| T2 anomalie visible | Prometheus : premier point hors norme |
| T3 alerte ML | Journal du service d'inférence (WOR-53) |
| T4, T5 décision, action terminée | Événements publiés par le moteur de remédiation (WOR-38) |
| T6 reprise vérifiée | Moteur de remédiation : transaction test et contrôle de cohérence réussis |

### Données

1. Le générateur de trafic enregistre chaque transaction **confirmée** (identifiant, montant).
2. Après la reprise, on compare cette liste au contenu de la base.
3. **Transactions manquantes + transactions en double = RPO mesuré.** L'objectif est 0.

### Grille de résultats

À remplir pendant les répétitions (WOR-78) : trois essais minimum par attaque.

| Essai | Attaque | T1 → T3 détection | T3 → T6 reprise | RTO mesuré | Transactions perdues ou dupliquées | Objectif tenu ? |
|---|---|---|---|---|---|---|
| 1 | A | | | | | |
| 2 | A | | | | | |

| Essai | Attaque | T1 → T3 détection | T3 → T6 reprise | RTO mesuré | Transactions perdues ou dupliquées | Objectif tenu ? |
|---|---|---|---|---|---|---|
| 3 | A | | | | | |
| 1 | B | | | | | |
| 2 | B | | | | | |
| 3 | B | | | | | |

On retient le **pire des trois essais**, pas la moyenne : un RTO se garantit, il ne s'espère pas.

## 7. Ce que le code permet de tenir au 20/10

- **RPO = 0 : pas tenable en l'état.** Il n'existe aucune sauvegarde de la base ; la seule remise en état repart des données de départ. Minimum avant les essais : un `pg_dump` avant chaque essai.
- **Délai de détection : pas mesurable.** Le modèle de détection n'existe pas encore ; seule l'extraction des features (fenêtre de 60 s, pas de 10 s) est codée.
- **Vérification de la reprise (T6) : à construire.** `/health` répond toujours « ok » ; la preuve de reprise doit être une transaction de test réussie, pas ce contrôle.

Détail et sources : `constat/etat-implementation.md`.

## 8. Ce que ces objectifs ne couvrent pas

- **Perte du PC Hôte** (panne, rançongiciel R7) : pas de deuxième site, donc pas de RTO tenable. La reprise passe par une réinstallation depuis le dépôt Git (WOR-49), sans objectif chiffré. C'est un risque résiduel assumé, à porter dans le PCA/PRA (WOR-71).
- **Sauvegardes sur le même hôte** : le RPO de 0 ne tient que si la base n'est pas détruite avec son hôte.
- **Faux positif du modèle ML** : une remédiation déclenchée à tort provoque elle-même une coupure, que le RTO doit absorber. À mesurer pendant le chaos engineering (WOR-76).

# PCA / PRA — Plateforme de paiement RESILIENCE-ALPHA

> ***Statut : cible.*** *Ce document décrit ce que l'équipe vise et a décidé, pas ce qui est déjà codé. L'état réel du code est suivi dans `constat/etat-implementation.md`.*

> *Ticket : WOR-71 · Responsable : Cédric · Version 0.1 du 19/10/2026*
>
> *Ce plan s'appuie sur la matrice de risques (`ebios-rm.md`), le coût d'un arrêt (`services-critiques.md`), les objectifs de reprise (`rto-rpo.md`) et l'analyse réglementaire (`nis2-dora.md`).*
>
> ***Statut :*** *les mécanismes décrits sont ceux **prévus** pour le démonstrateur. Au 20/10, le moteur de remédiation, le modèle de détection et les sauvegardes ne sont pas encore codés : voir `constat/etat-implementation.md`. Chaque fiche sera confirmée ou corrigée après les essais de restauration (WOR-75), le chaos engineering (WOR-76) et les répétitions (WOR-78).*
>
> *Ce document est indexé par l'assistant RAG (WOR-56). Chaque fiche scénario est donc rédigée pour être lue seule.*

## 1. Objet et périmètre

- **PCA (plan de continuité)** : comment le service de paiement **continue** pendant l'incident, en mode normal ou dégradé.
- **PRA (plan de reprise)** : comment on **revient** à un état sain et vérifié après l'incident, avec quelles données.

| Dans le périmètre | Hors périmètre |
|---|---|
| Plateforme Docker Compose du PC Hôte : front, authentification, API de paiement, base de données, WAF, supervision, détection ML, moteur de remédiation, assistant RAG | Infrastructure du campus, postes des autres groupes |
| Incidents de disponibilité, d'intégrité, défaillances internes, perte de l'hôte | Données réelles : toutes les données sont fictives |

## 2. Rôles et responsabilités

### 2.1 Dans l'entreprise fictive

| Rôle | Responsabilité pendant un incident |
|---|---|
| **Moteur de remédiation (automate)** | Premier intervenant : détecte, décide, agit et vérifie dans le périmètre d'actions qui lui est autorisé |
| **Opérateur d'astreinte** (équipe production) | Surveille le tableau de bord, reprend la main si l'automate échoue ou sort de son périmètre |
| **Responsable de la production** | Décide des restaurations de données et des modes dégradés |
| **RSSI** | Qualifie les incidents de sécurité, décide de la préservation des preuves et de la rotation des secrets |
| **Directeur de crise** (direction des opérations) | Pilote la cellule de crise, arbitre entre reprise rapide et investigation |
| **Conformité** | Classe l'incident selon DORA et prépare les notifications à l'ACPR |
| **Communication** | Informe les partenaires commerçants |
| **DPO** | Évalue l'atteinte aux données personnelles (RGPD) |

### 2.2 Dans l'équipe du démonstrateur

| Membre | Ce qu'il porte dans ce plan |
|---|---|
| Michael (Développement) | Moteur de remédiation, vérification de la reprise, cohérence des données |
| Reza (Infrastructure) | Playbooks Ansible, sauvegardes et restauration, remise à l'état sain |
| Léa (IA / Data) | Détection ML, assistant RAG |
| Axel (Cybersécurité) | WAF, SIEM, secrets, préservation des journaux |
| Cédric (Gouvernance) | Ce plan, classification des incidents, notifications, retour d'expérience |

## 3. Niveaux de réponse et escalade

Les seuils viennent du coût d'un arrêt (`services-critiques.md`).

| Niveau | Déclencheur | Qui agit | Gravité |
|---|---|---|---|
| **N0 — Automatique** | Alerte ML ou SIEM | Moteur de remédiation seul ; l'opérateur est informé | G1 |
| **N1 — Astreinte** | Échec de la remédiation, **ou** service non rétabli à 5 min, **ou** incident d'intégrité ou de confidentialité (même si la remédiation a réussi) | Opérateur d'astreinte, RSSI informé | G2 |
| **N2 — Cellule de crise** | Service non rétabli à 30 min, **ou** perte de données confirmée, **ou** compromission du moteur de remédiation | Directeur de crise, RSSI, conformité, communication | G3 |
| **N3 — Crise majeure** | Service non rétabli à 2 h, **ou** perte du PC Hôte | Direction générale | G4 |

**Règle de l'automate :** l'automate ne tente **pas plus de 3 remédiations en 10 minutes** sur le même service. Au-delà, il s'arrête et passe en N1, pour éviter une boucle de redémarrages qui aggraverait l'arrêt.

## 4. Fiches scénarios

### Fiche S1 — Déni de service sur l'API de paiement (attaque A)

- **Risque EBIOS :** R1 (hacktiviste, ER1) · gravité G4 si non traité
- **Signaux :** latence et taux d'erreurs 5xx en forte hausse, débit anormal depuis une ou quelques sources, transactions en échec
- **Actions automatiques :**
  1. Limitation de débit au WAF pour la ou les sources identifiées
  2. Redémarrage propre de l'API si elle ne répond plus
  3. Vérification : transaction test réussie, latence revenue au niveau normal
- **Données :** aucune restauration, la base n'est pas touchée
- **Objectif :** RTO ≤ 5 min (cible démonstrateur ≤ 60 s) · RPO = 0
- **Escalade :** N1 si l'attaque reprend depuis d'autres sources après la limitation
- **Retour à la normale :** limitation levée après 30 min sans trafic anormal, ou sur décision de l'opérateur
- **Risques résiduels :**
  - L'attaquant change d'adresse : la limitation par source ne suffit plus (un vrai déni de service distribué exige une protection en amont, hors de portée du prototype)
  - Un partenaire légitime au fort volume peut être limité à tort

### Fiche S2 — Injection applicative et altération de données (attaque B)

- **Risque EBIOS :** R2 (cybercriminel, ER2) · gravité G4
- **Signaux :** règle WAF déclenchée, motif anormal dans les journaux de l'API, erreurs applicatives, incohérence détectée dans les données
- **Actions automatiques :**
  1. Blocage de la source au WAF
  2. **Copie des journaux et de l'état de la base compromise** (preuves), avant toute restauration
  3. Restauration de la base depuis le dernier snapshot sain, puis rejeu des transactions légitimes (arbitrage en cours, voir `rto-rpo.md` §5)
  4. Rotation du secret concerné
  5. Vérification : transaction test réussie **et** contrôle d'intégrité des données
- **Objectif :** RTO ≤ 5 min (cible ≤ 3 min) · RPO = 0 transaction confirmée perdue
- **Escalade : N1 systématique**, même si la reprise réussit. Le RSSI qualifie l'incident ; la conformité évalue s'il est majeur au sens de DORA (une perte de données après un accès malveillant suffit)
- **Retour à la normale :** après correction de la vulnérabilité exploitée. D'ici là, la règle WAF reste active
- **Risques résiduels :**
  - La vulnérabilité est toujours dans le code : le WAF n'est qu'un pansement
  - Une porte dérobée a pu être déposée ; restaurer les données ne la supprime pas
  - Le snapshot « sain » peut contenir une altération plus ancienne, passée inaperçue
  - Après la rotation des secrets, les utilisateurs doivent se reconnecter

### Fiche S3 — Panne d'un service sans attaque

- **Couvre :** arrêt brutal d'un conteneur, saturation mémoire, base injoignable (testé par le chaos engineering, WOR-76)
- **Signaux :** contrôle de santé en échec, métriques absentes
- **Actions automatiques :** redémarrage du service ; si la base est en cause, vérification de son intégrité avant de relancer l'API
- **Objectif :** RTO ≤ 5 min · RPO = 0
- **Escalade :** N1 au-delà de 3 redémarrages en 10 minutes
- **Risques résiduels :** une cause profonde (disque plein, fuite mémoire) fera revenir la panne

### Fiche S4 — Remédiation déclenchée à tort (faux positif du modèle ML)

- **Risque :** non intentionnel, cité dans `ebios-rm.md`
- **Signaux :** remédiation exécutée sans anomalie confirmée par un second signal (SIEM, contrôle de santé)
- **Conduite à tenir :**
  1. Les actions de type S1 (limitation, redémarrage) restent autorisées : elles sont réversibles et courtes
  2. Les actions destructrices (restauration de la base, rotation des secrets) **exigent deux signaux concordants** (ML et WAF ou SIEM). Sinon, l'automate passe en N1
- **Risques résiduels :** une coupure courte provoquée par la défense elle-même ; elle est comptée dans le RTO

### Fiche S5 — Moteur de remédiation défaillant ou détourné

- **Risque EBIOS :** R3 (initié malveillant, ER6) · gravité G4
- **Signaux :** action hors du périmètre autorisé, appel au moteur depuis un composant non autorisé, rafale d'actions
- **Conduite à tenir :**
  1. Arrêter le moteur de remédiation
  2. Passer en **surveillance manuelle** : l'opérateur suit le tableau de bord et applique les fiches à la main
  3. Préserver les journaux du moteur
- **Escalade :** N2 immédiat
- **Prévention :** périmètre d'actions limité, authentification des appels, journalisation (WOR-64)
- **Risques résiduels :** pendant l'arrêt du moteur, plus aucune reprise automatique ; on retombe sur un RTO manuel de 30 min ou plus

### Fiche S6 — Suspicion de fuite de données

- **Risque EBIOS :** R5 (ER3) · gravité G3
- **Signaux :** volume de lecture anormal, requêtes inhabituelles sur la base, sortie de données vers une destination inconnue
- **Conduite à tenir :** couper l'accès de la source, préserver les preuves, **ne pas restaurer** (restaurer n'efface pas une fuite), prévenir le DPO
- **Escalade :** N2
- **Remarque :** non joué pendant la démo ; la fiche montre que la réponse diffère d'une simple remise en service (WOR-39)

### Fiche S7 — Perte du PC Hôte (PRA)

- **Risque EBIOS :** R7 (rançongiciel) ou panne matérielle · gravité G4
- **Conduite à tenir :**
  1. Préparer une machine de remplacement (prérequis du README, WOR-49)
  2. Cloner le dépôt Git, redéployer avec Docker Compose et les playbooks Ansible
  3. Régénérer les secrets : Vault tourne sur le PC Hôte, son contenu est perdu avec lui. Le déploiement en crée de nouveaux quand `infra/.env` est absent
  4. Restaurer la dernière sauvegarde de la base, **si elle existe hors de l'hôte**
- **Objectif :** aucun objectif chiffré tenable avec un seul hôte
- **Risques résiduels : perte de toutes les données depuis la dernière copie hors hôte**. C'est le principal écart du démonstrateur (voir §8)

## 5. Mode dégradé

Quand la reprise automatique échoue, on maintient ce qui peut l'être :

| Service | En mode dégradé | Interdit |
|---|---|---|
| Paiement | Limitation de débit stricte : on accepte moins de transactions plutôt qu'aucune | — |
| WAF | Mode de filtrage strict | **Le contourner** pour rétablir le trafic plus vite |
| Consultation | Lecture seule, voire suspendue pour soulager la base | — |

| Service | En mode dégradé | Interdit |
|---|---|---|
| Supervision | Surveillance manuelle sur le tableau de bord | — |
| Assistant RAG | Peut être arrêté pour libérer des ressources | Lui donner des droits d'action (WOR-57) |

## 6. Choix de restauration

| Élément | Où se trouve la référence saine | Comment on restaure | Fréquence | Responsable |
|---|---|---|---|---|
| Code et configuration des services | Dépôt Git, version taguée (WOR-80) | Redéploiement Docker Compose et Ansible | À chaque livraison | Reza |
| Règles du WAF | Dépôt Git | Rechargement à chaud | À chaque modification | Axel |
| Secrets | HashiCorp Vault, sur le PC Hôte | Rotation puis redémarrage des services concernés | Après tout incident d'intégrité | Axel |
| Base de données | **Aucune sauvegarde au 20/10.** Cible : snapshot + journal des transactions (`rto-rpo.md` §5) | Restauration du snapshot puis rejeu | Minimum : un `pg_dump` avant chaque essai | Reza, Michael |
| Journaux | Loki, rétention 7 jours, sur le PC Hôte | **Jamais écrasés** ; copiés avant toute restauration. Au 20/10, la remise à l'état sain les supprime sans copie | En continu | Axel |
| Modèle ML | Dépôt Git (`ml/`) | Rechargement de la version validée | À chaque entraînement | Léa |
| Index du RAG | Documents du dépôt | Réindexation | À chaque mise à jour des documents | Léa |

> ***Ne pas confondre restauration et remise à l'état sain.*** *La remise à l'état sain (`scripts/reset-known-good.sh`, WOR-90) supprime les volumes pour rejouer un essai : elle efface les transactions,* ***mais aussi les journaux Loki et les métriques Prometheus****, donc les preuves. Elle ne doit* ***jamais*** *servir à reprendre après un incident réel.*

## 7. Communication et notification

| Destinataire | Quand | Quoi | Qui |
|---|---|---|---|
| Opérateur d'astreinte | Dès N0 | Alerte et état de la reprise sur le tableau de bord | Automate |
| Partenaires commerçants | Dès N1 si leurs transactions échouent | Nature de la gêne, heure de reprise estimée | Communication |
| ACPR, incident majeur au sens de DORA | Notification initiale dans les 4 h après la classification en majeur (et au plus tard 24 h après la détection), rapport intermédiaire sous 72 h, rapport final sous 1 mois | Formulaire réglementaire, à partir des journaux du SIEM | Conformité |

| Destinataire | Quand | Quoi | Qui |
|---|---|---|---|
| CNIL | Sous 72 h en cas de violation de données personnelles | Notification RGPD | DPO |

Les délais de notification DORA sont à vérifier sur le texte officiel avant le rendu final. L'assistant RAG peut préparer un brouillon de notification à partir des journaux ; un humain le valide et l'envoie.

## 8. Risques résiduels après la reprise

| Risque résiduel | Pourquoi il subsiste | Traitement proposé |
|---|---|---|
| L'attaquant revient, depuis une autre source | La limitation est faite par source, sur un seul hôte | Protection anti-déni de service en amont (contexte industriel) |
| Vulnérabilité toujours présente après une injection | Le WAF bloque, mais le code n'est pas corrigé | Correctif et test de non-régression avant de lever le niveau N1 |
| Porte dérobée ou altération ancienne | Restaurer les données ne nettoie pas tout | Analyse après incident à partir des journaux conservés |
| Hôte unique | Point de défaillance unique | Deuxième site et sauvegardes hors site (`nis2-dora.md` §4) |
| Sauvegardes sur le même hôte | Perdues avec l'hôte | Copie hors site, immuable |
| Boucle de remédiation | Un incident persistant peut faire redémarrer un service en boucle | Limite de 3 remédiations en 10 minutes, puis escalade |
| Faux positifs ML | Un modèle entraîné sur peu de données | Deux signaux exigés pour les actions destructrices ; réentraînement |
| Droits élevés du moteur de remédiation | Nécessaires pour agir sur les conteneurs | Périmètre limité, authentification, journalisation (WOR-64) |

## 9. Tests et maintien du plan

| Test | Ticket | Scénarios vérifiés | Résultat |
|---|---|---|---|
| Premiers tests de restauration | WOR-75 | S2, S7 (en partie) | À remplir |
| Chaos engineering | WOR-76 | S3, S4 | À remplir |
| Démo complète répétée 3 fois | WOR-78 | S1, S2 | À remplir, temps dans `rto-rpo.md` §6 |

Le plan est mis à jour après chaque test et après chaque incident (retour d'expérience, DORA art. 13).

## 10. Décisions en attente

1. Méthode de restauration de la base après une injection (snapshot seul, ou snapshot et rejeu) : Michael, Reza.
2. Fréquence des snapshots de la base : Reza.
3. Règle des deux signaux pour les actions destructrices et limite de 3 remédiations : à intégrer au moteur (WOR-38) si l'équipe valide.

# Recommandations à la direction

> ***Statut : cible.*** *Ce document décrit ce que l'équipe vise et a décidé, pas ce qui est déjà codé. L'état réel du code est suivi dans* `constat/etat-implementation.md`*.*

> *Ticket : WOR-72 · Responsable : Cédric · Version 0.1 du 19/10/2026*
>
> *Synthèse des travaux de gouvernance :* `ebios-rm.md`*,* `services-critiques.md`*,* `nis2-dora.md`*,* `rto-rpo.md`*,* `pca-pra.md`*. Les mesures citées comme preuves seront renseignées après les essais (WOR-79) ; d'ici là, elles sont marquées à mesurer.*

## Synthèse pour la direction

1. **Un arrêt de paiement coûte peu pendant 5 minutes, puis le coût explose.** Une heure d'arrêt en pointe coûte environ 700 k€, essentiellement en pénalités contractuelles, et déclenche probablement une notification à l'ACPR au titre de DORA.
2. **La reprise automatique est donc l'investissement prioritaire.** Le démonstrateur vise un retour du service vérifié en moins d'une minute sur un déni de service, contre 30 minutes ou plus pour une reprise manuelle.
3. **Elle ne suffit pas pour une attaque sur l'intégrité des données.** Une injection impose de préserver les preuves, de vérifier les données et de notifier, même si le service revient vite. L'automate ne doit pas décider seul dans ce cas.
4. **Le démonstrateur repose sur un seul serveur.** C'est acceptable pour prouver le principe, pas pour la production : un deuxième site et des sauvegardes hors site sont la première dépense à prévoir.
5. **Nous demandons trois décisions** à la direction (dernière section).

## 0. Avant toute recommandation : ce que l'équipe doit livrer d'ici les essais

Au 20/10, plusieurs mécanismes sur lesquels reposent ces recommandations ne sont pas encore codés : moteur de remédiation, modèle de détection, sauvegarde de la base ; l'API n'est pas encore derrière le WAF. Sans eux, les éléments vérifiables cités ci-dessous resteront vides. La liste priorisée est dans `constat/etat-implementation.md` §4.

## 1. Les arbitrages que nous avons faits

| Arbitrage | Ce que nous avons choisi | Ce que nous avons écarté | Pourquoi | Ce que ça coûte |
|---|---|---|---|---|
| **Quoi protéger d'abord** | La chaîne de paiement : API, base, authentification, WAF | Protéger tous les services au même niveau | Ce sont eux qui portent le revenu et l'engagement envers les 200 partenaires | L'assistant RAG et la consultation passent après |
| **Automatique ou humain** | Automatique pour les actions réversibles (limitation, redémarrage) ; un humain valide les actions destructrices et les incidents d'intégrité | Tout automatiser, ou tout faire valider | La vitesse compte pour la disponibilité ; une restauration à tort coûte plus cher qu'une minute d'arrêt | Une injection est traitée moins vite qu'un déni de service |
| **Vitesse ou preuves** | Copier les journaux et la base compromise **avant** de restaurer | Restaurer au plus vite | Sans preuves, pas d'investigation ni de notification DORA crédible | Quelques secondes de plus sur la reprise |

| Arbitrage | Ce que nous avons choisi | Ce que nous avons écarté | Pourquoi | Ce que ça coûte |
|---|---|---|---|---|
| **Scénario principal de la démo** | Déni de service (risque R1) ; injection en second scénario | Une seule attaque | R1 est le risque le plus élevé ; le second scénario montre que la réponse dépend du type d'incident | Deux chaînes de remédiation à construire et tester |
| **Hébergement** | Tout sur un hôte, sans dépendance à un cloud | Services managés | Imposé par le cadre du projet ; évite aussi le risque lié à un prestataire | Point de défaillance unique, assumé et documenté |
| **Restauration après injection** | *À trancher* : snapshot seul, ou snapshot et rejeu des transactions légitimes | — | Le snapshot seul perd des transactions confirmées (objectif : zéro) | Le rejeu demande un journal des transactions |
| **Référentiels** | DORA, EBIOS RM ; NIS2 en grille de lecture | PCI DSS | Aucune donnée de carte manipulée | — |

## 2. Recommandations

Chaque recommandation repose sur un élément **vérifiable**, issu de nos essais ou de nos documents.

### Priorité 1 — à décider maintenant

| # | Recommandation | Élément vérifiable | Effort |
|---|---|---|---|
| REC-1 | **Généraliser la reprise automatique** aux incidents de disponibilité sur toute la chaîne de paiement | RTO mesuré sur 3 essais, pire cas retenu (*à mesurer*) ; nombre d'interventions humaines pendant les répétitions : objectif 0 (WOR-78) | Moyen |
| REC-2 | **Garder un humain dans la boucle pour les incidents d'intégrité** : blocage automatique, mais restauration et notification validées par une personne | Fiche S2 du PCA ; délai entre l'alerte et la décision humaine, à mesurer en exercice | Faible |
| REC-3 | **Exiger deux signaux concordants** avant toute action destructrice | Taux de faux positifs du modèle ML (WOR-52) ; nombre de remédiations à tort pendant le chaos engineering (WOR-76) (*à mesurer*) | Faible |
| REC-4 | **Encadrer le moteur de remédiation** comme un bien critique : périmètre d'actions limité, appels authentifiés, journalisation | Revue des droits du moteur (WOR-64) ; essai d'appel depuis un composant non autorisé, qui doit être refusé | Moyen |

### Priorité 2 — dans les 6 mois

| # | Recommandation | Élément vérifiable | Effort |
|---|---|---|---|
| REC-5 | **Sauvegardes hors site et immuables**, avec restauration testée chaque trimestre | Temps de restauration mesuré ; nombre de transactions perdues à la restauration | Moyen |
| REC-6 | **Restauration de la base à un instant précis** (archivage continu des journaux de la base), pour tenir zéro transaction perdue après une injection | Essai d'injection suivi d'une restauration, sans transaction légitime perdue | Moyen |
| REC-7 | **Procédure de notification DORA** : classification, brouillon préparé à partir des journaux, validation, envoi à l'ACPR | Exercice de notification chronométré face aux délais réglementaires | Faible |

| # | Recommandation | Élément vérifiable | Effort |
|---|---|---|---|
| REC-8 | **Programme annuel de tests de résilience** couvrant tous les risques retenus dans l'EBIOS, pas seulement le scénario de démo | Taux de couverture des risques R1 à R8 par au moins un test | Moyen |

### Priorité 3 — dans les 12 mois

| # | Recommandation | Élément vérifiable | Effort |
|---|---|---|---|
| REC-9 | **Deuxième site** (ou deuxième zone de disponibilité), avec bascule testée | Durée de bascule mesurée | Élevé |
| REC-10 | **Protection anti-déni de service en amont** du WAF, pour les attaques distribuées | Essai de charge distribuée | Moyen, souvent sous forme de service |
| REC-11 | **Gestion des prestataires TIC selon DORA** : registre, clauses contractuelles, plans de sortie | Registre à jour, contrats revus | Moyen |

**Ordre de grandeur pour arbitrer :** un seul incident de 30 minutes à 2 heures en pointe coûte environ 700 k€ (`services-critiques.md`). Les priorités 1 et 2 visent à ce qu'il ne se produise pas ; la priorité 3 protège contre la perte complète du site.

## 3. Ce que nous ferions autrement en contexte industriel

| Dans le démonstrateur | En production |
|---|---|
| Un seul hôte, sauvegardes locales | Deux sites, sauvegardes hors site et immuables |
| Un modèle ML entraîné sur quelques dizaines de minutes de trafic | Plusieurs semaines de données réelles, réentraînement régulier, suivi de la dérive du modèle |
| Deux scénarios d'attaque, joués par l'équipe | Programme de tests annuel, tests d'intrusion par des testeurs indépendants (TLPT si l'entité est désignée) |
| Notification décrite sur papier | Procédure exercée, astreinte conformité, modèles de rapports ACPR |
| Rôles fictifs (directeur de crise, RSSI, DPO) | Rôles nommés, suppléants, exercices de crise deux fois par an |
| Hypothèses financières fictives | Analyse d'impact sur l'activité menée avec les métiers et la finance |
| Gouvernance portée par l'équipe projet | Cadre de risque TIC approuvé par l'organe de direction, comme l'exige DORA (art. 5) |

## 4. Limites de cette analyse

- Les chiffres financiers sont **fictifs**. Ils donnent des ordres de grandeur, pas un budget.
- Les seuils DORA et les délais de notification sont repris de notre lecture des textes, à confirmer par un juriste.
- Les temps de reprise ne vaudront preuve qu'une fois mesurés (WOR-79). Si les mesures ne tiennent pas les objectifs, les recommandations REC-1 et REC-3 seront revues.

## 5. Décisions demandées à la direction

1. **Valider le principe d'une reprise automatique** pour les incidents de disponibilité, avec validation humaine pour les incidents d'intégrité (REC-1, REC-2).
2. **Accepter le risque résiduel de l'hôte unique** pour la phase pilote, et **inscrire au budget** les sauvegardes hors site (REC-5) puis le deuxième site (REC-9).
3. **Désigner les responsables** des rôles du PCA (directeur de crise, conformité, astreinte) et planifier un premier exercice de crise.

# État d'implémentation face à la gouvernance

> ***Statut : constat.*** *Ce document décrit ce qui a été vérifié dans le code, avec ses sources. Les objectifs et les plans sont dans `cible/`.*

> *Responsable : Cédric · Version 0.1 du 20/10/2026 · Relevé sur `main` après la fusion des PR #14 (code de la plateforme dans `app/`), #16 (WAF) et #17 (SIEM)*
>
> *Les documents de gouvernance ont été écrits avant le code. Ce registre dit, pour chaque hypothèse importante, si le code la **confirme**, la **contredit** ou ne l'a **pas encore implémentée**. Il est à mettre à jour après chaque fusion importante et avant les essais (WOR-73).*

## 1. Ce qui existe au 20/10/2026

| Composant | État | Où |
|---|---|---|
| API de paiement (Node.js) avec authentification par session, idempotence des paiements, métriques Prometheus, journaux JSON | Implémentée | `app/backend/` |
| Front web et page d'administration | Implémentés | `app/front/` |
| Base PostgreSQL de l'application | Implémentée, **sans sauvegarde** | `app/infra/docker-compose.yml`, `app/infra/database/init/001_schema.sql` |
| Socle : Vault, PostgreSQL, Prometheus (collecte toutes les 5 s), Loki (rétention 7 jours), Grafana | Implémenté, **mais l'API n'y est pas encore branchée** | `infra/docker-compose.yml` |
| Extraction des features de détection (fenêtre de 60 s, pas de 10 s) | Implémentée | `ml/features/extract.py` |
| Modèle de détection, envoi des alertes | **Absent** | `ml/training/`, `ml/inference/` vides |
| Moteur de remédiation | **Absent** | `services/remediation/README.md` : « À implémenter » |
| WAF ModSecurity + OWASP CRS, en mode bloquant, seul point d'entrée publié du socle | Implémenté. **Mais l'API n'est pas encore derrière lui** : le trafic légitime reçoit une erreur 502, les injections sont bloquées en 403. Pas d'interface pour ajouter un blocage à chaud : les règles changent par fichier, puis redémarrage | `infra/docker-compose.yml`, `infra/waf/README.md` |

| Composant | État | Où |
|---|---|---|
| Tableau de bord SOC / SIEM dans Grafana : blocages du WAF, accès à Vault, flux corrélé WAF · Vault · PostgreSQL | Implémenté ; **aucune règle d'alerte** | `infra/grafana/provisioning/dashboards/soc-siem.json` |
| Tableau de bord d'incident (WOR-40) | **Absent** ; la page d'administration affiche des statuts fixes | `services/dashboard/`, `app/backend/api/src/main.ts` |
| Remise à l'état sain | Implémentée ; **efface base, journaux, métriques et Vault** | `scripts/reset-known-good.sh` |
| Assistant RAG en lecture seule | Implémenté | `rag/docker-compose.rag.yml` |
| Scripts d'attaque A et B | Implémentés, **à recâbler sur la vraie API** (voir §3) | `attack/` |

Il existe **quatre déploiements Docker Compose séparés** (application, socle, labo IA, RAG), avec deux bases PostgreSQL différentes. Tant qu'ils ne sont pas réunis, la chaîne attaque → détection → remédiation → vérification ne peut pas être jouée de bout en bout.

## 2. Hypothèses de la gouvernance confrontées au code

| Hypothèse | Document | Verdict | Constat |
|---|---|---|---|
| Aucune transaction confirmée perdue (RPO = 0) | `cible/rto-rpo.md` | **Non implémenté** | Aucune sauvegarde, aucun archivage des journaux de la base. La seule « reprise » des données est la remise à l'état sain, qui repart des données de départ |
| Après une injection : snapshot puis rejeu des transactions légitimes | `cible/rto-rpo.md` §5, `cible/pca-pra.md` S2 | **Non implémenté** | Pas de snapshot. Point toujours à trancher avec Michael et Reza |
| Deux signaux concordants avant une action destructrice | `cible/pca-pra.md` S4 | **Non implémenté** | Ni moteur, ni modèle. Les runbooks parlent de deux fenêtres consécutives d'une même famille, ce qui n'est pas deux signaux indépendants |
| Au plus 3 remédiations en 10 minutes par service | `cible/pca-pra.md` §3 | **Non implémenté** | Les runbooks prévoient une escalade après 2 tentatives (`docs/runbooks/reprise.md`) : à harmoniser |
| Journaux copiés avant toute restauration | `cible/pca-pra.md` S2, §6 | **Contredit** | La remise à l'état sain supprime les journaux Loki sans copie |
| Assistant RAG sans accès privilégié | `cible/pca-pra.md` §5 | **Confirmé** | Conteneur en lecture seule, sans droits ni accès au moteur Docker |
| Hôte unique, aucune sauvegarde hors de l'hôte | `cible/nis2-dora.md`, `cible/pca-pra.md` S7 | **Confirmé** | Inventaire Ansible local uniquement |

| Hypothèse | Document | Verdict | Constat |
|---|---|---|---|
| Secrets dans HashiCorp Vault | `cible/ebios-rm.md` BS9 | **Partiellement contredit** | Vrai pour le socle. L'application a son mot de passe de base en clair dans son fichier Compose, et sa clé d'API OpenAI en variable d'environnement |
| Collecte toutes les 5 s, détection en 20 à 70 s | `cible/rto-rpo.md` §4 | **En partie confirmé** | Collecte à 5 s et fenêtre de 60 s confirmées. Le délai de détection ne peut pas être mesuré : il n'y a pas encore de détecteur |
| Une injection altère des données, qu'il faut ensuite restaurer | `cible/pca-pra.md` S2 | **Contredit par le WAF** | Le WAF du socle bloque 9 vecteurs sur 10 de l'attaque B en 403, avant l'API (`infra/waf/README.md`). La protection est démontrée ; la restauration ne peut pas l'être tant qu'aucune injection n'atteint la base |
| Vérification de la reprise par une transaction réelle | `cible/rto-rpo.md` §1 | **À construire** | `/health` répond toujours « ok » sans rien vérifier : il ne peut pas servir de preuve de reprise |

## 3. Nouveaux constats à intégrer à l'analyse de risques (WOR-67)

| Constat | Risque concerné | Gravité du constat |
|---|---|---|
| Port de la base de l'application (55432) publié sur toutes les interfaces, avec un mot de passe en clair dans le dépôt | R5 exfiltration | **Élevée** : la base est joignable depuis le réseau `RESILIENCE-G6` |
| L'assistant de discussion de l'application envoie les messages des utilisateurs à OpenAI | Fuite de données (ER3), prestataire TIC tiers (DORA art. 28) | Moyenne : données fictives, mais incohérent avec un assistant « local » |
| Code de vérification des paiements fixe (`123456` par défaut) **et renvoyé dans la réponse de l'API** (`demoCode`) | R4 usurpation, R2 fraude | Moyenne en démo, critique en production : la vérification ne protège rien |
| Limitation de débit sur la connexion (12 essais / 15 min), mais pas de verrouillage de compte | R4 bourrage d'identifiants | Faible : la limitation freine déjà l'attaque |
| Vault avec une seule part de clé, clé de descellement et jeton root dans un fichier de l'hôte | R3, R7 | Moyenne : acceptable pour un prototype, à citer en limite |
| Attaque A dirigée sur `/health` du labo IA, attaque B sur `/api/pay`, qui n'existe ni dans l'application ni dans le labo | Validité des essais | **Élevée** : l'attaque B ne modifie aucune donnée, il n'y a donc rien à restaurer. La réponse « restauration » ne peut pas être démontrée en l'état |
| Pas de solde ni de débit dans le modèle de données (intentions de paiement uniquement) | ER2 altération | Faible : le risque devient « paiements altérés ou dupliqués » ; l'idempotence protège déjà contre les doublons |

## 4. Ce qu'il faut avant les essais de mercredi

Par ordre de priorité, pour que la démo prouve ce que la gouvernance affirme :

1. **Brancher l'API de l'application sur le socle**, derrière le WAF (qui renvoie aujourd'hui 502 faute de backend), collectée par Prometheus et Loki, avec une seule base. Infrastructure, Développement.
2. **Remplacer `/health` par une vérification réelle** : base joignable et transaction de test réussie. Développement.
3. **Construire le moteur de remédiation** (WOR-38), avec la vérification de la reprise. Développement.

4. **Entraîner le modèle et envoyer les alertes** (WOR-52, WOR-53). IA / Data.
5. **Recâbler les attaques A et B** sur les vraies routes de l'API. Pour l'attaque B, **décider ce qu'on démontre** : le blocage par le WAF (déjà obtenu), ou la restauration, qui suppose qu'une injection passe le WAF et écrive en base. Cybersécurité, Gouvernance.
6. **Une sauvegarde de la base avant chaque essai**, au minimum un `pg_dump` horodaté, conservé hors des volumes purgés. Infrastructure.
7. **Fermer le port 55432 et passer les secrets de l'application dans Vault.** Cybersécurité.
8. **Copier les journaux avant toute remise à l'état sain**, pour garder les preuves des essais. Infrastructure.